

Security Assessment Report

Generated: 2026-05-04 15:31

Report ID: a4cf0d66

Executive Security Report

Executive Summary

Total vulnerabilities: 3

Highbatch issues: 0 critical/high findings identified; however, the application has security weaknesses that could enable unsafe subprocess execution and poor input trust boundaries.

Overall risk level: Medium

Technical Details

Finding 1 Unsafe subprocess usage in scan execution

Severity: Low

AI Explanation: The code launches external tools with subprocess.run() using values derived from user input. Even if shell injection is not directly used, this pattern increases the risk of command misuse and unexpected execution behavior.

Fix Suggestion: Validate and normalize paths before execution, use explicit absolute tool paths, and restrict accepted input to approved directories.

Finding 2 Partial executable path for Bandit invocation

Severity: Low

AI Explanation: Bandit flags the use of "bandit" without a full path. Relying on PATH can be risky in hardened or compromised environments because a different executable could be resolved.

Fix Suggestion: Call Bandit using a trusted absolute path or managed virtual environment entrypoint.

Finding 3 Importing subprocess in a securitysensitive API

Severity: Low

AI Explanation: The application imports and uses subprocess to run scanning commands. In a service that accepts usercontrolled scan targets, this expands the attack surface and should be tightly controlled.

Fix Suggestion: Wrap tool execution in a dedicated allowlistbased service layer with strict input validation and leastprivilege permissions.

Tool outcomes

Bandit: Succeeded

Sonar: Succeeded

Safety: Failed — No requirements.txt found in project

ZAP: Failed — Not applicable for this local code review; no URL target was provided

Tool Failures

Safety could not run because the project does not contain a requirements.txt file.

ZAP was not executed because the input was source code, not an HTTP/HTTPS target.